

Analisi di Threat Intelligence e Indicatori di Compromissione in Ambiente di Laboratorio

Studio del Traffico di Ricognizione e Scansione

Relazione di Laboratorio – Esercitazione di Ethical Hacking

Data: 7 agosto 2026

Ambiente: Laboratorio Virtuale Isolato (VirtualBox)

1. Introduzione

1.1 Contesto e Finalità Didattiche

Nel campo della cybersecurity, la Threat Intelligence rappresenta una disciplina fondamentale per la prevenzione e il rilevamento delle minacce. Gli Indicatori di Compromissione (IOC — *Indicators of Compromise*) costituiscono gli artefatti tecnici che, opportunamente analizzati, consentono di identificare attività sospette o malevole all'interno di un sistema o di una rete. Il riconoscimento tempestivo di tali indicatori è prerequisito essenziale per l'attivazione di protocolli di incident response e per la messa in sicurezza delle infrastrutture informatiche.

Il presente elaborato ha lo scopo di documentare, con rigore metodologico e formalismo accademico, l'esercitazione pratica condotta nel corso del modulo dedicato alla Threat Intelligence e agli IOC. L'obiettivo didattico consiste nell'analizzare una cattura di rete al fine di: (1) individuare eventuali evidenze di attività anomale; (2) formulare ipotesi sui vettori di attacco potenzialmente impiegabili; (3) proporre azioni correttive e preventive per la riduzione dell'impatto di attacchi attuali e futuri.

1.2 Struttura del Documento

La relazione è articolata come segue. Il §2 descrive lo scenario sperimentale e l'architettura del laboratorio. Il §3 illustra la metodologia di analisi adottata. I §4 e §5 presentano, rispettivamente, i risultati della fase di ricognizione passiva e della fase di scansione attiva, con l'individuazione degli IOC. Il §6 propone un'analisi approfondita dei rischi associati e delle relative contromisure. Il §7 conclude il lavoro con considerazioni finali e lezioni apprese.

1.3 Disclaimer Etico e Legale

Si precisa, sin da ora, che l'intera attività descritta nel presente documento è stata condotta esclusivamente in ambiente di laboratorio virtuale, isolato da qualsiasi rete di produzione, e nel rispetto dei principi dell'ethical hacking. Le tecniche di scansione e di analisi del traffico sono state applicate su sistemi di proprietà dell'autore e dedicati alla formazione accademica, senza alcun intento di accesso non autorizzato a sistemi di terzi. Il documento è redatto a fini puramente didattici e di ricerca.

2. Scenario Sperimentale e Architettura del Laboratorio

2.1 Descrizione dell'Ambiente Controllato

L'esercitazione è stata condotta all'interno di un ambiente virtualizzato, realizzato mediante l'impiego di Oracle VirtualBox. L'infrastruttura è stata progettata per simulare uno scenario realistico di analisi di rete, garantendo al contempo l'isolamento totale dal contesto esterno. La comunicazione tra le macchine virtuali è avvenuta attraverso un'interfaccia di rete interna, configurata in modalità host-only, al fine di prevenire fughe di traffico verso la rete fisica dell'host.

2.2 Asset Coinvolti

Nella tabella seguente sono riepilogati i sistemi impiegati durante l'esercitazione, con le relative funzioni e configurazioni di rete.

Indirizzo IP	Ruolo	Sistema Operativo / Software	Note
192.168.50.100	Macchina Attaccante	Kali Linux (Nmap 7.99)	Utilizzata per le scansioni di rete
192.168.50.150	Macchina Target	Metasploitable (Samba 3.0.20-Debian)	Sistema vulnerabile per scopi didattici
192.168.200.100	Macchina Attaccante (sessione alternativa)	Kali Linux	Cattura in subnet diversa per analisi comparativa
192.168.200.150	Macchina Target (sessione alternativa)	Metasploitable	Oggetto della cattura Wireshark fornita

Tabella 1 — Asset dell'infrastruttura di laboratorio

Si evidenzia che gli indirizzi IP rientrano nelle classi private definite dalla RFC 1918, coerentemente con le best practice per la realizzazione di ambienti di test.

3. Metodologia di Analisi

3.1 Framework di Threat Intelligence

L'approccio investigativo adottato si ispira al ciclo di intelligence della cybersecurity, articolato nelle fasi di raccolta, elaborazione, analisi e disseminazione. In particolare, l'indagine si è concentrata sulla ricerca di artefatti riconducibili alla fase iniziale della kill chain: la *ricognizione (Reconnaissance)*, suddivisa in: (1) *ricognizione passiva*: raccolta

di informazioni senza interazione diretta con il target; (2) *ricognizione attiva*: interazione diretta con il target per l'enumerazione di servizi e vulnerabilità.

3.2 Strumenti Utilizzati

Gli strumenti impiegati durante l'esercitazione sono elencati di seguito:

Strumento	Versione	Funzione
Wireshark	4.x	Cattura e analisi del traffico di rete a livello di pacchetto
Nmap	7.99	Port scanner per l'enumerazione dei servizi attivi
Terminale Bash	—	Esecuzione dei comandi e gestione dei file di cattura

Tabella 2 — Strumenti utilizzati

4. Fase di Ricognizione Passiva: Analisi del Traffico Broadcast

4.1 Identificazione degli Asset Tramite Protocollo SMB Browser

L'analisi preliminare della cattura di rete ha evidenziato la presenza di pacchetti del protocollo **SMB MailSlot / Microsoft Windows Browser Protocol**, trasmessi in modalità broadcast dall'host target. Tali pacchetti rivelano l'annuncio periodico della macchina **METASPLOITABLE** all'interno del dominio di workgroup.

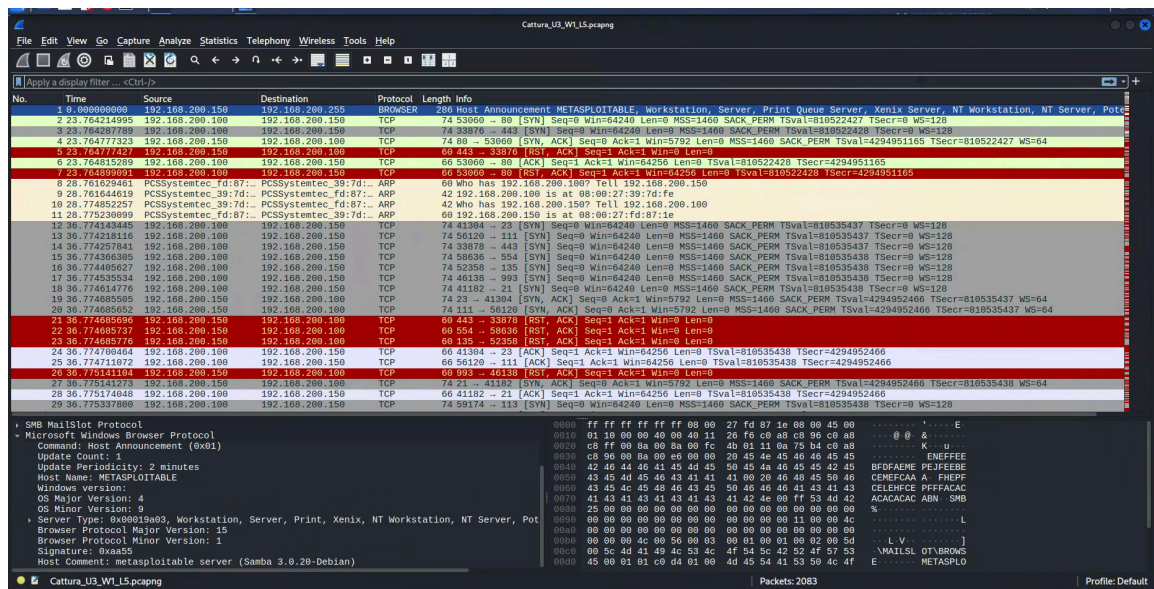
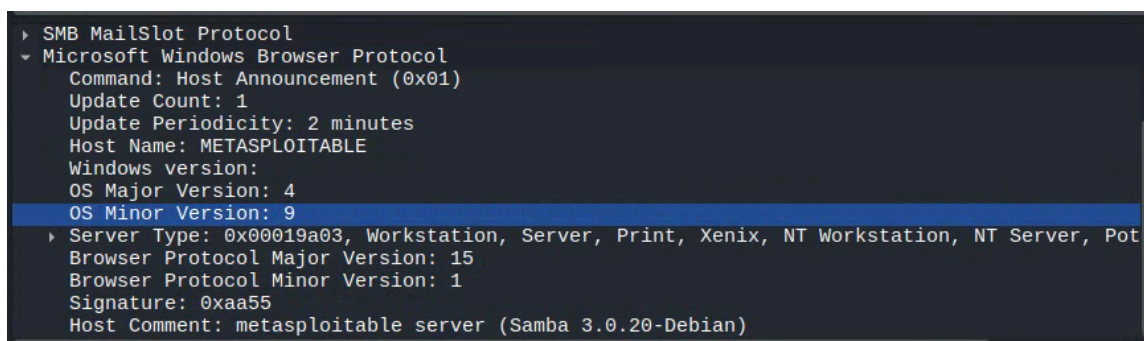


Figura 1 — Cattura Wireshark: Host Announcement SMB e primi pacchetti di scansione TCP

La figura illustra il pacchetto di Host Announcement (0x01) trasmesso dall'indirizzo 192.168.200.150 verso la subnet broadcast (192.168.200.255), contestualmente all'inizio dell'attività di scansione TCP SYN proveniente dall'host 192.168.200.100.

L'ispezione approfondita del payload del pacchetto SMB (Figura 2) ha consentito di estrarre informazioni critiche per il fingerprinting del sistema target:

- Host Name: METASPLOITABLE
- OS Major Version: 4
- OS Minor Version: 9
- Host Comment: metasploitable server (Samba 3.0.20-Debian)



```

SMB MailSlot Protocol
Microsoft Windows Browser Protocol
  Command: Host Announcement (0x01)
  Update Count: 1
  Update Periodicity: 2 minutes
  Host Name: METASPLOITABLE
  Windows version:
  OS Major Version: 4
  OS Minor Version: 9
  Server Type: 0x00019a03, Workstation, Server, Print, Xenix, NT Workstation, NT Server, Pot
  Browser Protocol Major Version: 15
  Browser Protocol Minor Version: 1
  Signature: 0xaa55
  Host Comment: metasploitable server (Samba 3.0.20-Debian)

```

Figura 2 — Dettaglio del protocollo SMB Browser: fingerprinting del sistema operativo

L'immagine mostra il campo "Host Comment" che espone esplicitamente la versione del servizio Samba (3.0.20) e la distribuzione sottostante (Debian), fornendo all'attaccante informazioni preziose per la ricerca di vulnerabilità note.

È importante sottolineare che il traffico SMB Browser analizzato non costituisce di per sé un attacco, bensì una normale attività di annuncio di presenza (*Local Master Announcement*) generata dal demone Samba in esecuzione sul target. Tuttavia, dal punto di vista della Threat Intelligence, tali pacchetti rappresentano un **Indicatore di Compromissione di tipo informazionale** (IOC), in quanto forniscono all'attaccante dati essenziali per la pianificazione di successive fasi offensive.

4.2 Analisi delle Richieste ARP

Contestualmente al traffico SMB, la cattura evidenzia scambi di pacchetti ARP (Address Resolution Protocol) tra gli host del laboratorio. Le richieste ARP di tipo 'Who has [IP]? Tell [IP]' sono funzionali alla risoluzione degli indirizzi fisici (MAC) necessari per la comunicazione a livello data-link. Tali pacchetti, sebbene legittimi in una rete locale,

possono essere considerati precursori di attività di scansione, in quanto precedono sistematicamente l'invio dei segmenti TCP SYN.

5. Fase di Ricognizione Attiva: Scansione delle Porte e Identificazione degli IOC

5.1 Scansione Mirata su Porte di Servizio Specifiche

Si è proceduti all'esecuzione di una scansione mirata mediante il comando Nmap, finalizzata a verificare lo stato delle porte 80 (HTTP) e 443 (HTTPS) sul target 192.168.50.150:

```
nmap -p 80,443 192.168.50.150
```

L'output del comando ha evidenziato quanto segue: (1) Porta 80/tcp: stato open, servizio http; (2) Porta 443/tcp: stato closed, servizio https.

No.	Time	Source	Destination	Protocol	Length	Info
8	28.761629461	PCSSystemtec_fd:87::...	PCSSystemtec_39:7d::...	ARP	60	who has 192.168.200.100? Tell 192.168.200.150
9	28.761644619	PCSSystemtec_39:7d::...	PCSSystemtec_fd:87::...	ARP	42	192.168.200.100 is at 08:00:27:39:7d:fe
10	28.774052257	PCSSystemtec_39:7d::...	PCSSystemtec_fd:87::...	ARP	42	who has 192.168.200.150? Tell 192.168.200.100
11	28.775230999	PCSSystemtec_fd:87::...	PCSSystemtec_39:7d::...	ARP	60	192.168.200.150 is at 08:00:27:fd:87:1e
12	36.774143445	192.168.200.100	192.168.200.150	TCP	74	41304 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
13	36.774231116	192.168.200.100	192.168.200.150	TCP	74	50120 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33878 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
15	36.774366395	192.168.200.100	192.168.200.150	TCP	74	59636 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
16	36.774495627	192.168.200.100	192.168.200.150	TCP	74	52358 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
17	36.774535554	192.168.200.100	192.168.200.150	TCP	74	46138 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
18	36.774614770	192.168.200.100	192.168.200.150	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
19	36.774685505	192.168.200.100	192.168.200.150	TCP	74	23 → 41384 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36.774689552	192.168.200.150	192.168.200.100	TCP	74	111 → 50120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
21	36.774695696	192.168.200.150	192.168.200.100	TCP	60	443 → 33878 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.774695737	192.168.200.150	192.168.200.100	TCP	60	554 → 59636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.774695776	192.168.200.150	192.168.200.100	TCP	60	135 → 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36.774700464	192.168.200.100	192.168.200.150	TCP	66	41304 → 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.774711072	192.168.200.100	192.168.200.150	TCP	66	50120 → 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36.774711104	192.168.200.150	192.168.200.100	TCP	60	993 → 46138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Figura 3 — Esecuzione di Nmap su porte specifiche e cattura Wireshark in parallelo

La figura mostra il terminale Kali Linux con il risultato della scansione mirata, affiancato alla cattura Wireshark in tempo reale. Si osservano i pacchetti TCP SYN inviati dall'host 192.168.50.100 verso le porte 80 e 443 del target, seguiti rispettivamente da un segmento SYN-ACK (porta aperta) e da un segmento RST-ACK (porta chiusa).

La cattura di rete conferma l'impiego della tecnica di TCP connect scan (o SYN scan a livello di implementazione di Nmap), caratterizzata dall'invio di un pacchetto SYN e dall'analisi della risposta del target per determinare lo stato della porta.

5.2 Scansione Massiva SYN (Half-Open Scan)

Successivamente, è stata condotta una scansione più aggressiva sulle prime 1024 porte TCP del target, utilizzando la tecnica SYN (*half-open*) con elevata velocità di esecuzione:

```
sudo nmap -sS -T4 -p -1024 192.168.50.150
```

I risultati ottenuti (Figura 4) hanno rivelato un'ampia superficie di attacco, con numerosi servizi attivi:

Porta	Stato	Servizio
21/tcp	open	ftp
22/tcp	open	ssh
23/tcp	open	telnet
25/tcp	open	smtp
53/tcp	open	domain
80/tcp	open	http
111/tcp	open	rpcbind
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
512/tcp	open	exec
513/tcp	open	login
514/tcp	open	shell

Tabella 3 — Risultato della scansione SYN sulle prime 1024 porte

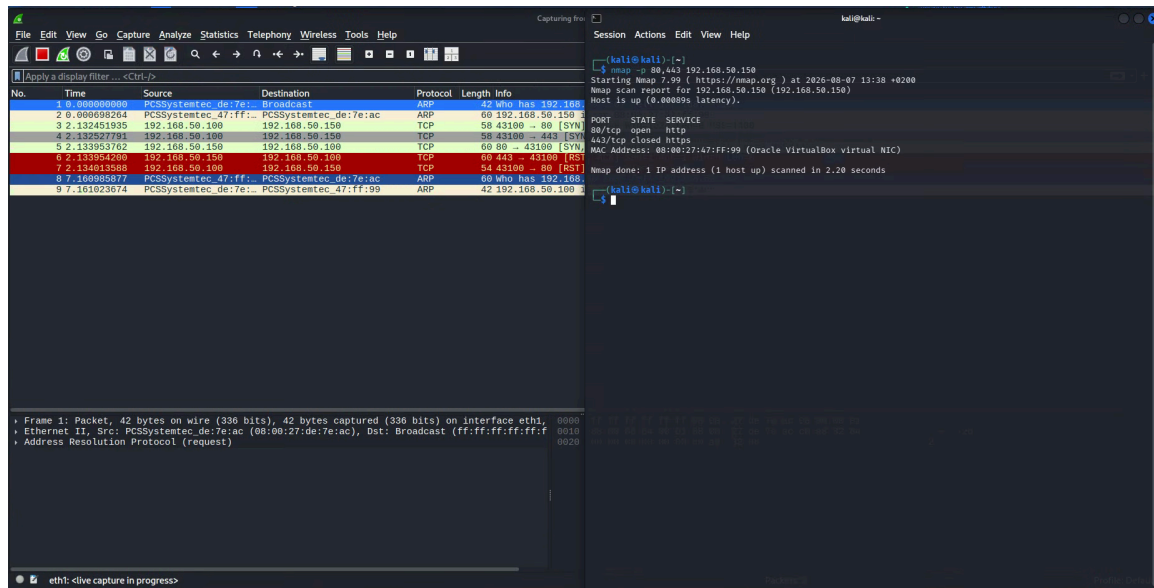


Figura 4 — Esecuzione della scansione SYN massiva e enumerazione dei servizi attivi

L'immagine riporta l'output completo del comando Nmap, evidenziando le 12 porte aperte identificate sul target. In parallelo, la cattura Wireshark mostra la sequenza di pacchetti SYN inviati in rapida successione, tipica di una scansione automatizzata.

L'analisi del traffico generato ha inoltre permesso di osservare il comportamento del target in risposta alla scansione: per le porte aperte, il target ha risposto con segmenti SYN-ACK, mentre per le porte chiuse ha restituito pacchetti RST-ACK. La presenza di pacchetti RST-ACK in uscita dal target verso l'attaccante è indicativa di porte non in

ascolto, ma rappresenta comunque un'interazione rilevabile e loggabile.

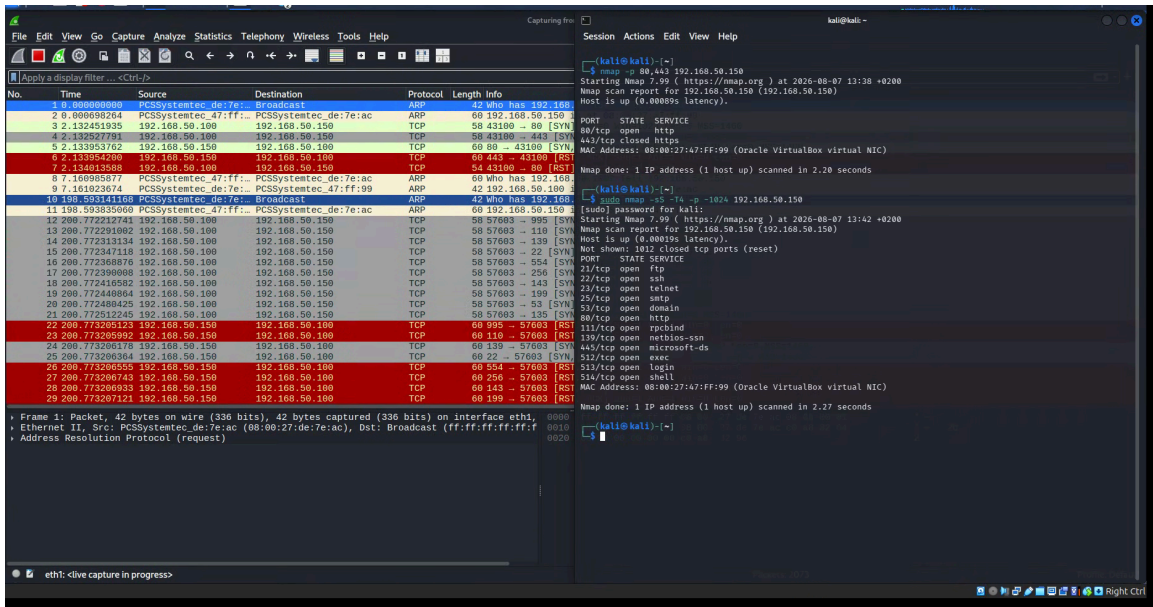


Figura 5 — Sequenza di pacchetti TCP SYN e RST-ACK durante la scansione multi-porta

La figura mostra un estratto della cattura Wireshark relativo alla fase di scansione, in cui si osservano segmenti SYN diretti verso porte diverse (23, 111, 443, 554, 135, 993, 21) e le corrispondenti risposte RST-ACK, testimonianza di un'attività sistematica di port enumeration.

5.3 Classificazione degli Indicatori di Compromissione

In base all'analisi condotta, sono stati identificati e classificati i seguenti IOC, riassunti nella Tabella 4:

ID	Tipo di IOC	Descrizione	Fase MITRE ATT&CK	Livello di Rischio
IOC-001	Informazionale	Host Announcement SMB con leak di versione (Samba 3.0.20-Debian)	Reconnaissance (T1592)	Medio
IOC-002	di Rete	Richieste ARP anomale in sequenza rapida	Reconnaissance (T1018)	Basso
IOC-003	di Rete	Pacchetti TCP SYN verso multiple porte in intervalli temporali ristretti	Reconnaissance (T1046)	Alto
IOC-004	di Rete	Risposte RST-ACK massicce dal target verso un	Reconnaissance (T1046)	Medio

		singolo host sorgente		
IOC-005	di Host	Enumerazione di servizi legacy (Telnet, FTP, rlogin) esposti su rete	Reconnaissance (T1590)	Critico

Tabella 4 — Matrice di classificazione degli Indicatori di Compromissione identificati

Si sottolinea che gli IOC rilevati non dimostrano di per sé una compromissione avvenuta, ma testimoniano un'intensa attività di ricognizione, riconducibile alla fase iniziale della *Cyber Kill Chain*. La presenza di servizi obsoleti e non crittografati (Telnet, FTP, rlogin su porte 23, 21, 513, 514) costituisce tuttavia un fattore di rischio critico, in quanto espone il target a potenziali attacchi di tipo man-in-the-middle o credential sniffing.

5.4 Analisi del Traffico BROWSER di Workgroup

La cattura ha inoltre evidenziato pacchetti di Local Master Announcement e Domain/Workgroup Announcement (Figura 6), tramessi dal target verso l'indirizzo broadcast della subnet.

No.	Time	Source	Destination	Protocol	Length	Info
2873	285.687427437	PCSSystemtec.de:7e::: PCSSystemtec.47:ff:99	42 192.168.50.100 is at 08:00:27:de:7e:ac	ARP	42	Request for 192.168.50.100
2874	285.687427437	192.168.50.150	192.168.50.255	BROWSER	257	Local Master Announcement (type 2)
2875	334.792188841	192.168.50.150	192.168.50.255	BROWSER	257	Domain/Workgroup Announcement (type 257)

Figura 6 — Pacchetti BROWSER: Local Master Announcement e Domain/Workgroup Announcement

La figura mostra i pacchetti di annuncio del workgroup "WORKGROUP", con flag NT Workstation e Domain Enum attivi. Tali pacchetti sono generati automaticamente dal servizio Samba e non costituiscono un attacco, ma forniscono informazioni sulla topologia logica della rete.

6. Analisi dei Rischi e Contromisure

6.1 Valutazione del Rischio Associato agli IOC

L'identificazione degli IOC descritti nel §5 consente di formulare una valutazione del rischio secondo il paradigma della *Likelihood* (probabilità) e dell'*Impact* (impatto). La matrice che segue sintetizza la pericolosità delle evidenze rilevate:

IOC	Probabilità di Escalation	Impatto Potenziale	Rischio Complessivo
IOC-001 (Leak versione Samba)	Alta	Medio	Medio-Alto

IOC-003 (SYN scan multi-porta)	Alta	Medio	Alto
IOC-005 (Servizi legacy esposti)	Molto Alta	Alto	Critico

Tabella 5 — Matrice di valutazione del rischio

La presenza concomitante di un'attività di scansione attiva (IOC-003) e di servizi vulnerabili o deprecati (IOC-005) determina uno scenario ad alto rischio, in quanto l'attaccante dispone sia degli strumenti di discovery sia dei vettori di attacco necessari per procedere alla fase successiva della kill chain (weaponization / exploitation).

6.2 Ipotesi sui Vettori di Attacco Potenziali

In virtù degli IOC rilevati, è possibile formulare le seguenti ipotesi sui vettori di attacco impiegabili in una fase offensiva successiva:

1. **Exploit di Samba (CVE note):** la versione 3.0.20 è notoriamente affetta da vulnerabilità critiche (es. CVE-2007-2447, Samba 'username map script' Command Execution), che consentirebbero l'esecuzione di codice remoto con privilegi elevati.
2. **Attacco ai servizi Telnet/FTP non crittografati:** l'intercettazione del traffico su tali porte permetterebbe il furto di credenziali in chiaro, abilitando l'accesso non autorizzato al sistema.
3. **Remote Shell via rlogin/rsh (porte 512-514):** i servizi rexec, rlogin e rshell sono storicamente noti per l'assenza di autenticazione robusta e potrebbero essere sfruttati per l'accesso interattivo remoto.
4. **Enumerazione RPC e NetBIOS (porte 111, 139, 445):** l'accesso a questi servizi potrebbe consentire il mapping delle risorse condivise e l'estrazione di informazioni sensibili (es. hash NTLM, elenchi utenti).

6.3 Contromisure Tecniche

Per mitigare i rischi identificati, si propone l'adozione delle seguenti contromisure tecniche, organizzate per livello di implementazione:

a) Livello di Rete

- Segmentazione e VLAN: isolare il server in una zona demilitarizzata (DMZ) o in una VLAN dedicata, limitando la visibilità dei pacchetti broadcast a livello di dominio di collisione.
- Firewall di nuova generazione (NGFW): implementare regole stateful che limitino il numero di connessioni SYN per secondo provenienti da un singolo host (protezione SYN flood / scan detection).
- IDS/IPS: distribuire sensori di rilevamento delle intrusioni (es. Snort, Suricata) con regole specifiche per l'identificazione di scansioni Nmap (es. regole ET SCAN).

b) Livello di Host

- Hardening del sistema operativo: disabilitare tutti i servizi non strettamente necessari, in particolare Telnet, FTP anonimo, rlogin e rshell.
- Aggiornamento dei pacchetti: aggiornare immediatamente Samba alla versione più recente e stabilire una procedura di patch management ricorrente.
- Configurazione sicura di Samba: rimuovere il commento che espone la versione del software; implementare l'autenticazione SMB signing; limitare l'accesso alle share tramite ACL.

c) Livello di Applicazione

- Sostituzione di protocolli non sicuri: migrare da Telnet a SSH, da FTP a SFTP/SCP, implementando sempre l'autenticazione a chiave pubblica.
- Principio del minimo privilegio: configurare i servizi attivi per l'esecuzione con account non privilegiati (service accounts).

6.4 Contromisure Procedurali e Organizzative

Oltre alle misure tecniche, risulta indispensabile rafforzare il perimetro umano e procedurale:

- Monitoraggio continuo: implementare un SIEM (Security Information and Event Management) per la correlazione degli eventi di rete e l'allerta tempestiva su pattern di scansione.

- Threat Intelligence attiva: sottoscrivere feed di intelligence per il rilevamento di IP sospetti e per l'aggiornamento continuo delle firme di attacco.
- Formazione del personale: sensibilizzare gli amministratori di sistema ai rischi associati all'esposizione di servizi legacy e alle tecniche di footprinting.
- Incident Response Plan: definire procedure documentate per la risposta agli incidenti, inclusa la catena di escalation e le modalità di contenimento.

7. Considerazioni Finali e Lezioni Apprese

L'esercitazione condotta ha confermato l'importanza cruciale della fase di ricognizione nell'economia di un attacco informatico. L'analisi della cattura Wireshark ha dimostrato che anche attività apparentemente innocue — quali le broadcast SMB o le scansioni di porte — generano artefatti rilevabili e classificabili come IOC. La capacità di distinguere tra traffico legittimo, ricognizione passiva e scansione attiva rappresenta una competenza fondamentale per l'analista di sicurezza.

È emerso, inoltre, che l'ambiente Metasploitable, per sua natura deliberatamente vulnerabile, espone una superficie di attacco eccessivamente ampia, rendendo evidenti le conseguenze di una cattiva gestione dei servizi di rete. La coesistenza di protocolli deprecati (Telnet, rlogin) e di versioni obsolete di software di condivisione file (Samba 3.0.20) costituisce un campionario emblematico delle configurazioni che, purtroppo, ancora oggi si riscontrano in contesti produttivi non adeguatamente mantenuti.

Dal punto di vista metodologico, l'integrazione tra strumenti di cattura passiva (Wireshark) e strumenti di scansione attiva (Nmap) ha permesso di correlare il traffico di rete con le azioni dell'attaccante, fornendo una visione olistica del processo di reconnaissance. Tale approccio, replicato in un contesto aziendale, consentirebbe di identificare tempestivamente un potenziale avversario ancora nella fase preparatoria, offrendo al blue team un vantaggio temporale decisivo per l'attuazione delle contromisure.

In conclusione, il presente lavoro ribadisce che la cybersecurity non può prescindere da una gestione proattiva della visibilità di rete: ogni pacchetto trasporta informazioni; la

capacità di leggerle, interpretarle e contestualizzarle è il presupposto indispensabile per la costruzione di una difesa resiliente e consapevole.